《未来技术》大作业项目补充说明

一、基本信息

- 姓名：肖信羽
- 学号：2435102090646
- 班级：24 人工智能 6 班
- 项目名称：个人开销统计仪表盘 — 基于原生 HTML/CSS/JS + Django REST Framework + JWT 的可视化开销管理工具
- 项目类型：自选项目（课程大作业）
- GitHub 仓库地址：https://github.com/pourtourAJJK/WL_QMDZY_XXY.git
- 提交分支：main
- 最终提交：867a51f Merge branch 'feature/fix-xlsx-html-import' into main
- 仓库状态：public

二、项目介绍

个人开销统计仪表盘是一个面向学生与个人用户的记账与可视化 Web 应用。用户注册登录后，可逐笔录入金额、类别、日期与备注，系统实时生成类别占比环形图、月度支出柱状图、类别堆叠柱状图与每日支出折线图，帮助用户看清“钱花到了哪里”。项目采用前后端分离架构：前端为原生 HTML/CSS/JavaScript（ES2020，零构建），后端为 Django 5.2 + Django REST Framework 3.18（端口 8000）；数据存于 SQLite，按登录用户严格隔离。认证使用 PBKDF2-SHA256 加盐哈希与 JWT 双令牌，并配合服务端失败锁定与接口限流。

1. 用户认证与安全：PBKDF2 加盐哈希 + JWT 双令牌 + 服务端锁定 + 接口限流

① 用户认证：注册 / 登录 / 登出，密码由后端 PBKDF2-SHA256 随机盐哈希存储（1,000,000 次迭代），登录签发 access（30 分钟）与 refresh（1 天）双令牌，登出时后端将 refresh 拉黑；
② 服务端安全防护：连续 5 次密码错误锁定账号 5 分钟（LoginAttempt 表持久化，换浏览器不失效），登录 / 注册 / 导入 / 导出接口分别限流；
③ 开销完整 CRUD：金额 + 类别 + 日期 + 备注，新增 / 删除 / 清空全部走后端接口，按用户隔离；
④ 可视化：环形图、月度柱状图、类别堆叠柱状图、每日折线图 + 三张统计卡片；
⑤ 数据导入：JSON / CSV / XLSX 上传后端逐行校验，兼容记账软件导出的“HTML 表格伪装 .xls/.xlsx”，任一行非法则整份拒绝，事务回滚保护原数据；
⑥ 数据导出：JSON / CSV 前端生成，XLSX 由后端 openpyxl 生成（表头样式、列宽、冻结首行、金额格式）；
⑦ 交互细节：类别筛选、7 个预置类别、自定义类别、响应式布局。

提供账号注册、登录、登出功能，每个用户拥有独立的 JWT 会话与专属开销数据，多用户数据严格隔离。浏览器端只保存令牌（sessionStorage），不再保存账号、密码哈希或开销明细。

连续 5 次密码错误后，该账号在服务端锁定 5 分钟；锁定状态的判定与倒计时均由后端返回，刷新页面或更换浏览器都不会解锁。登录、注册、导入、导出接口分别设置限流阈值。

2. 开销管理与可视化：完整 CRUD + 四张图表 + 三张统计卡片

四张 ECharts 图表（类别占比环形图、月度支出柱状图、类别堆叠图、当月每日折线图）与三张统计卡片（累计总支出、本月支出、最高单笔）在数据变化或类别筛选时统一刷新。

支持开销的新增、删除与清空；列表按日期倒序展示，可按类别筛选，列表与所有图表同步刷新。越权删除他人记录返回 404，且原数据不受影响。

导入文件上传到后端逐行解析与校验，校验包括金额范围、日期格式、类别长度与备注长度；任一行非法则整份拒绝，并在事务内先删后插，失败自动回滚，保护既有数据。

导出的 XLSX 列为“日期 / 类别 / 金额 / 备注 / 创建时间”，与导入端支持的中文表头一致，因此导出文件可直接再导入，形成“导出 → 清空 → 再导入”的闭环。

3. 运行环境与启动方法

- 运行环境：Python 3.10+（Django 后端）、现代浏览器（Chrome / Edge / Safari）。前端零构建，无需 Node。
  安装依赖命令：
  后端：cd backend && pip install -r requirements.txt
  前端：无需安装，原生 HTML/CSS/JS
- 启动命令：
  后端：cd backend && python manage.py migrate（首次）&& python manage.py runserver 127.0.0.1:8000
  前端：cd src && python -m http.server 8080
- 访问方式：
  前端界面 http://localhost:8080
  后端 API http://127.0.0.1:8000/api/
  演示账号：自行注册任意用户名（3 位以上）与密码（6 位以上），无预置账号

4. 核心使用流程

用户首次打开 http://localhost:8080 看到登录界面。点击“注册”创建账号（3 位以上用户名 + 6 位以上密码），注册成功后切回登录页登录。登录成功后进入主仪表盘，浏览器只保存 JWT 令牌，开销数据全部从后端拉取。

主界面自上而下依次为：顶部用户信息与登出按钮 → 开销录入表单（金额 / 类别 / 日期 / 备注）→ 三张统计卡片 → 四张图表 → 开销明细列表（日期倒序、类别筛选、单条删除）→ 数据管理区（导出 / 导入 / 清空）。

录入一笔开销后，后端落库并返回完整记录；前端重新拉取快照，环形图、月度柱状图、堆叠图、折线图与统计卡片同步刷新。示例输入：35 / 餐饮 / 今天 / 外卖，120 / 购物 / 今天 / 超市，8 / 交通 / 今天 / 地铁。

数据管理区可导出 JSON / CSV / XLSX。其中“导出为 Excel”会向 GET /api/expenses/export/ 发起带 JWT 的请求，由后端 openpyxl 生成工作簿并下载；点击“导入备份”上传该 xlsx，后端逐行校验后覆盖写入，即可验证“导出 → 清空 → 再导入”的完整闭环。

安全演示：在登录页连续输错 5 次密码，第 5 次即返回 423 锁定，界面显示服务端倒计时；此时刷新页面或换浏览器仍保持锁定。

5. 当前完成情况与已知问题

已完成功能：

☑ 用户注册 / 登录 / 登出（PBKDF2 加盐哈希 + JWT 双令牌 + refresh 黑名单）
☑ 服务端连续 5 次失败锁定 5 分钟（跨浏览器生效）
☑ 登录 / 注册 / 导入 / 导出接口限流
☑ 开销完整 CRUD（新增 / 删除 / 清空），按用户隔离
☑ 四张图表 + 三张统计卡片，录入后自动刷新
☑ 类别筛选 + 7 个预置类别 + 自定义类别
☑ JSON / CSV / XLSX 导入（服务端逐行校验、事务回滚，兼容 HTML 表格伪装的 .xls/.xlsx）
☑ XLSX 导出（后端 openpyxl 生成，可直接再导入）
☑ 自动化验证：后端单测 34/34、XLSX 回环 30/30、接口联调 23/23、前端模块联调 15/15

已知局限：

⚠ SQLite 与 LocMem 限流仅适合单进程演示，生产环境需 PostgreSQL + Redis
⚠ 自定义类别保存在浏览器 localStorage，未随账号同步到后端
⚠ HTML 伪 Excel 导入仅取第一张 <table>；真正的旧版二进制 .xls 需另存为 .xlsx 后导入
⚠ PDF 文档导入与语音转写尚未实现（原计划功能被中断）
⚠ 浏览器自动化逐点击验证未完成，需按第 4 节流程人工复核

三、BMAD-Method 工作流使用记录（重要）

以下内容均以仓库中真实存在的产物文件与 Git 提交为准，对应提交填写“短哈希 + 提交说明”，教师可逐一打开核对。

阶段	我实际使用了什么（技能 / 方式）	产物文件路径（仓库内相对路径）	对应提交（短哈希 + 说明）	验证方式与结果
需求分析	BMAD 四阶段工作流：bmad-product-brief + bmad-prd，产出产品简报与需求规格	_bmad-output/planning-artifacts/product-brief.md、_bmad-output/planning-artifacts/prd.md	b81b9ff docs: 完成产品简报与需求规格	产物文件可核对 + 核心流程可现场演示
规划与设计	bmad-architecture + bmad-create-epics-and-stories，产出技术架构与 5 Epic / 12 Story	_bmad-output/planning-artifacts/architecture.md、_bmad-output/planning-artifacts/epics-and-stories.md	e94599d docs: 完成技术架构与任务拆分	架构图、模块依赖与任务清单可核对
开发实现	原生 HTML/CSS/JS + Django 5.2 +	src/、backend/accounts/、backend/expenses/、	f5436ad / 7ae30f0 /	双服务启动，注册 → 登录 →

	DRF 3.18；按 Epic 建 feature 分支逐模块实现后 --no-ff 合并	backend/config/	b5aa51a / 52255a1 / 48de5f9 + 5 次合并	录入 → 图表刷新可演示
迭代增强	后端认证迁移（PBKDF2 + JWT + 锁定 + 限流）；XLSX 导出迁移到后端 openpyxl	backend/accounts/、backend/config/settings.py、backend/expenses/exporters.py	ac00469 feat: 新增 Django 后端认证；fae3579 feat: 新增 XLSX 服务端导出	后端单测 28 条 + XLSX 导出/导入回环 30/30
验证与改进	iteration-1~15 独立迭代文档 + 自动化测试 + 真实 HTTP 联调 + 缺陷修复（含 HTML 伪 Excel 导入兼容）	_bmad-output/implementation-artifacts/iteration-1.md ~ iteration-15.md、build-report.md、test-report.md	3df6fbc test: E2E 22/22 PASS；14b87e0 test: 后端 24/24；c4e727d test: XLSX 30/30 PASS；434a63a test: HTML 伪 Excel 6 条用例	后端 34/34、XLSX 回环 30/30、接口 23/23、前端模块 15/15

四、Git 使用记录

1. 分支使用

`main` 主分支，存放全部已合并的稳定代码。

本项目全程采用 feature 分支 + `--no-ff` merge 工作流，每个功能模块独立建分支、做完合并、删除分支，最终 main 上保留 15 条明确的合并痕迹。

15 个 feature 分支：feature/data-layer、feature/expense-form、feature/chart-dashboard、feature/expense-list、feature/data-management、feature/auth-login、feature/data-export-import、feature/chart-enhancement、feature/fix-chart-render、feature/fix-chart-promise-auth-persist、feature/ui-redesign、feature/docs-sync-readme、feature/backend-auth-jwt、feature/backend-xlsx-export、feature/fix-xlsx-html-import。

所有合并均使用 `git merge feature/xxx --no-ff` 方式，保留明确的分叉与合并痕迹；15 个 feature 分支全部合并后删除，仓库只保留 main 与 origin/main。

源分支	目标分支	合并提交（短哈希 + 说明）
feature/data-layer	main	76ddff2 Merge branch 'feature/data-layer' into main
feature/expense-form	main	00949ff Merge branch 'feature/expense-form' into main

feature/chart-dashboard	main	2e79f91 Merge branch 'feature/chart-dashboard' into main
feature/expense-list	main	07b6e69 Merge branch 'feature/expense-list' into main
feature/data-management	main	ef68659 Merge branch 'feature/data-management' into main
feature/auth-login	main	6c6da6e Merge branch 'feature/auth-login' into main
feature/data-export-import	main	a85d9c5 Merge branch 'feature/data-export-import' into main
feature/chart-enhancement	main	65ad638 Merge branch 'feature/chart-enhancement' into main
feature/fix-chart-render	main	569b860 Merge branch 'feature/fix-chart-render' into main
feature/fix-chart-promise-auth-persist	main	9f2faf4 Merge branch 'feature/fix-chart-promise-auth-persist' into main
feature/ui-redesign	main	384124e Merge branch 'feature/ui-redesign' into main
feature/docs-sync-readme	main	ad80375 Merge branch 'feature/docs-sync-readme' into main
feature/backend-auth-jwt	main	ffc6813 Merge branch 'feature/backend-auth-jwt' into main
feature/backend-xlsx-export	main	d57b896 Merge branch 'feature/backend-xlsx-export' into main
feature/fix-xlsx-html-import	main	867a51f Merge branch 'feature/fix-xlsx-html-import' into main

2. 关键提交列表

序号	短哈希	提交说明	主要内容
1	71988d0	first commit	初始化仓库
2	b81b9ff	docs: 完成产品简报与需求规格	product-brief.md + prd.md（BMAD 阶段一）
3	e94599d	docs: 完成技术架构与任务拆分	architecture.md + epics-and-stories.md（BMAD 阶段二）
4	f5436ad	feat: 完成基础设施与数据层	Story 1.1 + 1.2：数据模型与本地数据层
5	7ae30f0	feat: 完成开销录入表单	Story 2.1 + 2.2：表单校验与提交
6	b5aa51a	feat: 完成可视化仪表盘	Story 3.1–3.4：环形图 / 柱状图 / 折线图 + 三张卡片
7	52255a1	feat: 完成开销列表与筛选	Story 4.1 + 4.2：明细列表、类别筛选、删除
8	48de5f9	feat: 完成数据管理与模块整合	Story 5.1 + 5.2：导出导入、清空、统一刷新
9	b312312	feat: 完成登录认证模块	注册 / 登录 / 5 次失败锁定 / 登出（当时为前端实现）
10	9672769	feat: 导出导入支持 JSON/CSV/Excel	前端 SheetJS 导出 + 服务端导入校验
11	78c2f3d	feat: 图表可视化增强	修复图表问题 + 新增月度类别堆叠柱状图
12	cbada44	fix: 修复登录后图表白屏	onAuthReady 重复调用 + ECharts init 时序
13	9a7f96c	fix: 用 Promise 消除图表 init 竞态	await charts.init + 固定 8080 端口
14	3b0436b	style: UI 全面优化	去渐变 / 去重阴影 / 去 emoji + 设计令牌
15	ac00469	feat: 新增 Django 后端认证与开销接口	PBKDF2 + JWT + 服务端锁定 + 限流；前端改为

			JWT API 化
16	ffc6813	Merge branch 'feature/backend-auth-jwt' into main	后端认证分支合并
17	fae3579	feat: 新增 XLSX 服务端导出	openpyxl 生成 xlsx，移除前端 SheetJS CDN
18	d57b896	Merge branch 'feature/backend-xlsx-export' into main	XLSX 导出分支合并
19	4c799a7	fix: 兼容 HTML 表格伪装的 xls/xlsx 导入并修复前端缓存混跑	importers.py 内容嗅探 + 标准库解析第一张 <table>；index.html 静态资源加 ?v= 防缓存
20	434a63a	test: HTML 伪 Excel 导入 6 条用例与真实 HTTP 验证	单测 34/34 PASS + iteration-15.md
21	867a51f	Merge branch 'feature/fix-xlsx-html-import' into main	最终提交

3. 提交记录截图

请在下方插入一张提交记录截图（推荐 git log --oneline --graph，或 GitHub 仓库的 Commits / Network 页面，能看到提交顺序与分支合并）。

（此处插入提交记录截图，替换本行）

图 1 • git 提交记录与分支合并

五、运行截图或演示视频（二选一）

方式一：运行截图（至少 3 张）

每张截图注明：这是什么操作、看到什么结果。截图要能看见程序真实运行、真实的输入与输出；请按下列占位说明替换为本项目截图。

（此处插入运行截图，替换本行）

图 2 • 注册并登录后进入仪表盘（JWT 由后端签发）

（此处插入运行截图，替换本行）

图 3 • 录入开销后四张图表与统计卡片刷新

（此处插入运行截图，替换本行）

图 4 • 导出 XLSX → 清空 → 重新导入恢复数据

（此处插入运行截图，替换本行）

图 5 • 连续 5 次错误密码触发服务端锁定

六、遇到的问题与处理

问题 1：登录后图表白屏

发现方式：注册登录后仪表盘图表区域空白，控制台提示 ECharts 实例尚未初始化。

排查过程：onAuthReady 在一次登录流程中被重复触发，charts.init() 的异步初始化尚未完成就调用了 refreshAll；同时 ECharts 脚本与业务脚本存在执行顺序竞争。

最终处理：charts.init() 改为返回 Promise 并在 main.js 中 await，初始化只执行一次（businessModulesInited 标志），提交 cbada44 与 9a7f96c 修复。

问题 2：限流单元测试始终拿不到 429

发现方式：把登录限流阈值临时改小后连续请求，仍全部返回 401，限流逻辑无法被验证。

排查过程：DRF 的 SimpleRateThrottle.THROTTLE_RATES 在模块导入时已绑定为类属性，override_settings(REST_FRAMEWORK=...) 修改配置不会影响已绑定的类属性。

最终处理：测试内临时替换 ScopedRateThrottle.THROTTLE_RATES 并在 finally 中恢复，验证第 3 次请求返回 429；生产配置未改动。

问题 3：SheetJS CDN 不可达导致 Excel 导出失效

发现方式：HEAD 请求 cdn.jsdelivr.net 超时，页面中 XLSX 为 undefined，点击“导出为 Excel”直接失败。

排查过程：确认导出依赖前端第三方库，而导入已经在后端用 openpyxl 解析，前后端能力不一致；同时 CDN 可用性不受项目控制。

最终处理：新增 GET /api/expenses/export/，由后端 openpyxl 生成 xlsx（表头样式、列宽、冻结首行、金额格式），前端改用 api.download() 带 JWT 下载并删除 SheetJS CDN；提交 fae3579，并用真实 HTTP 完成“导出 → 清空 → 再导入”回环验证 30/30 PASS。

问题 4：导入 xlsx 弹窗报“Invalid HTML: could not find <table>”

发现方式：导入记账软件导出的 .xlsx 文件时前端弹窗报错，提示含英文“could not find <table>”。

排查过程：全仓库与全部 Python 依赖中均搜不到该字符串；对运行中的后端复现 5 种异常文件都只返回中文提示；最终在 SheetJS（xlsx.js）源码中定位到该 throw——确认浏览器标签页仍运行着 SheetJS 时代的旧版缓存前端，且该“.xlsx”文件内容实际是 HTML 网页（记账软件导出的“伪 Excel”，真 xlsx 应以 PK 开头）。

最终处理：后端 importers.py 改为内容嗅探优先于扩展名——识别到 HTML 时用标准库 HTMLParser 解析第一张 <table>（UTF-8 / GB18030 自动识别），遇到真正的旧版二进制 .xls 返回清晰中文提示；前端全部静态资源加 ?v= 版本号防止浏览器沿用旧缓存。提交 4c799a7；新增 6 条单测后 34/34 PASS，并用真实 HTTP 验证 HTML 伪 xlsx 导入成功、无表格网页与二进制 xls 均返回中文 400 提示。

七、提交前自查清单

- ☑ GitHub 仓库地址、分支、最终提交填写正确，教师能够访问（仓库为 public）；
- ☑ 提交历史完整，能看出“需求 → 规划 → 实现 → 验证”的推进过程；
- ☑ BMAD-Method 各阶段产物文件已在仓库中，每个阶段有对应提交；
- ☑ 至少使用过一次分支并合并，提交记录中有合并痕迹（15 次 --no-ff merge）；
- ☐ 已插入提交记录截图（待补充）；
- ☐ 已插入运行截图（或提供演示视频，待补充）；
- ☑ 没有上传密码、Token、私人令牌和真实隐私数据；
- ☐ 本次补充说明已提交到学习通（待提交）；
- ☐ 学习通答案区已填写 GitHub 仓库地址（待填写）。